

# GESTIÓN DE CIBERSEGURIDAD :

## Modificación no autorizada de información

### 1º.- Preparación

Inventario y clasificación de datos críticos del centro (notas de alumnos, expedientes, datos médicos, nóminas, trabajos de investigación).

Política de copias de seguridad offline/inmutable (3-2-1) para restaurar sin pagar rescates.

Formación a docentes y administrativos sobre phishing, robo de credenciales y uso de MFA (autenticación multifactor).

Simulacros de ataque ransomware y modificación de calificaciones.

Equipo de respuesta a incidentes (CSI-RT) con roles definidos: director TIC, jefe de estudios, asesor legal, responsable de protección de datos.

### 2º.- Identificación

Detección temprana mediante:

- Alertas de integridad de ficheros (ej. cambios masivos en notas en horario no lectivo).
- Usuario con acceso inusual desde IP no habitual o fuera de horario.
- Aviso de un profesor: "las notas han cambiado sin mi autorización".

Confirmación:

- Revisión de logs de la plataforma educativa (accesos, modificaciones, descargas masivas).
- Identificar si es ransomware (archivos con extensión extraña, nota de rescate) o modificación selectiva por credenciales robadas.

### 3º.- Contención

A corto plazo:

- Desconectar el equipo/servidor afectado de la red (física o lógicamente).
- Revocar credenciales del usuario comprometido.
- Cambiar contraseñas de cuentas administrativas y de la app educativa.
- Bloquear IPs maliciosas en el firewall.

A largo plazo:

- Aislar segmento de red de administración académica del de aulas o invitados.
- Deshabilitar servicios remotos innecesarios (RDP, SSH abiertos al exterior).

#### 4°.- Mitigación

Eliminar persistencia:

- Escaneo antivirus/EDR en busca de backdoors, keyloggers o tareas programadas maliciosas.
- Revisar cuentas de servicio y usuarios creados recientemente.

Si es ransomware:

- No pagar rescate (seguir guía del INCIBE-CERT para centros educativos).
- Restaurar desde copia de seguridad limpia.

Si es modificación con credenciales robadas:

Revisar todos los cambios realizados por ese usuario (rollback de transacciones en BD).

Auditar permisos: aplicar mínimo privilegio (un profesor no debe modificar notas de otro curso).

#### 5°.- Recuperación

Restauración de datos:

- Volcar copia de seguridad limpia (verificar integridad previamente).
- Comparar hash de archivos restaurados con los originales.

Validación funcional:

- Probar que la plataforma educativa funciona correctamente con datos recuperados.
- Notificar a los profesores afectados que sus calificaciones han sido restauradas.

Reconexión segura:

- Conectar sistemas nuevamente a la red monitorizando tráfico.
- Forzar cambio de contraseñas general en el centro.

#### 6°.- Actuaciones post-incidente (en base al centro educativo)

Análisis de causa raíz:

¿Fue phishing a un profesor? ¿Falta de MFA? ¿Puerto RDP abierto?

Documentar lecciones aprendidas en un informe para la dirección.

Medidas correctivas:

- Implementar MFA obligatorio en todas las cuentas del centro (alumnos, profesores, PAS).
- Revisar y endurecer permisos en el SGA (sistema de gestión académica).

- Establecer política de rotación de contraseñas cada 60 días.

Cumplimiento legal y notificaciones:

- Si se modificaron datos personales (LOPDGDD - RGPD): notificar a la AEPD en 72h y a los afectados (padres, alumnos).
- Informar a la aseguradora de ciberseguridad (si existe póliza).
- Mejora continua:
- Incluir el caso en el plan de formación anual.
- Revisar el plan de respuesta a incidentes cada semestre.

Comunicación interna y externa:

- Comunicado claro a la comunidad educativa (sin alarmismo, pero con transparencia).
- Si el incidente tuvo repercusión pública, preparar mensajes con apoyo de gabinete de comunicación.